

TRAINING @ FORREST ONE

Session 6 of 12

Network Fundamentals + CompTIA Security+ SY0-701

Cryptography & Public Key Infrastructure

The vocabulary of security, then the tools: symmetric and asymmetric encryption, hashing, signatures, certificates, blockchain, and the identity and access machinery that uses

LESSON 3

ENCRYPTION

PKI

IDENTITY



CHAPTER 1 · THE THREE JOBS & VOCABULARY

The CIA triad: three jobs, one question

- **Confidentiality** only authorised people can read the data, served by encryption, access controls and authentication
- **Integrity** the data is accurate and has not been altered, served by checksums, hashes and digital signatures
- **Availability** authorised users can reach data when they need it, served by redundancy, maintenance and load balancing
- **Cryptography meets identity** cryptography is the tool, and identity decides who may use it
- **Ask the question** which of the three does this control serve?
- **Every control here** serves confidentiality, integrity or availability



CHAPTER 1 · THE THREE JOBS & VOCABULARY

Saying what you mean: vulnerability, threat, exploit, risk

Term	Meaning
Vulnerability	A weakness in software, hardware or a process
Threat	Anything that could exploit a weakness, deliberate or accidental
Exploit	The method or tool used to take advantage of a vulnerability
Risk	Likelihood combined with impact, which is how you prioritise

A weakness that is likely to be used, and would hurt badly, is the one you fix first.



SESSION OBJECTIVES

By the end of this session you will be able to

- **Explain symmetric encryption** one shared key, fast, for bulk data, with the key-distribution problem
- **Explain asymmetric encryption** key pairs, RSA and elliptic curve, which solve distribution
- **Describe hashing and signatures** one-way digests for integrity; signing for authentication and non-repudiation
- **Describe public key infrastructure** certificate authorities, X.509, the chain of trust and revocation
- **Cover the paper trail** obfuscation, steganography, blockchain, documentation and version control
- **Manage identity and access** authentication versus authorisation, roles, factors, SSO and federation
- **Describe the access protocols** RADIUS, TACACS+ and LDAP, and the access control models



TOPIC 3A · CRYPTOGRAPHIC ALGORITHMS

Symmetric encryption and the Advanced Encryption Standard

- **Plaintext in, ciphertext out** and back again with the key
- **One shared key** the same secret encrypts and decrypts
- **AES** the Advanced Encryption Standard, with 128, 192 or 256-bit keys
- **Fast** so it protects whole disks, database files and backups
- **In the wild** BitLocker and FileVault both rely on it
- **The weak point** key distribution and key storage, never the algorithm



TOPIC 3A · CRYPTOGRAPHIC ALGORITHMS

Key length matters

- **Keyspace** the range of possible key values
- **Longer is stronger** each added bit doubles the work for an attacker
- **The comparison** a 256-bit key is exponentially stronger than a 128-bit key
- **Brute force** a larger keyspace defeats exhaustive search
- **The cost** longer keys use more CPU, memory and power
- **The balance** choose the strength the data actually needs



TOPIC 3A · CRYPTOGRAPHIC ALGORITHMS

Asymmetric encryption and key pairs

- **A linked pair** one public key and one private key, mathematically related
- **The rule** encrypt with the public key, and only the private key decrypts
- **RSA** from Rivest, Shamir and Adleman: the difficulty of factoring very large primes
- **Elliptic curve** comparable strength with far smaller keys, good for mobile and constrained devices
- **Distribution solved** public keys are shared openly, and the private key cannot be derived from them
- **Slower** so it protects keys and signatures rather than bulk data



CHAPTER 1 · THE THREE JOBS & VOCABULARY

How Transport Layer Security uses both

Stage	Encryption	Why
Handshake	Asymmetric	Establish trust and exchange a session key
Session key	Asymmetric	Only the server can decrypt it with its private key
Bulk data	Symmetric	Far faster for the rest of the session
Data at rest	Symmetric	Disks, databases and backups
Data in transit	TLS	Protects traffic crossing untrusted networks

Asymmetric solves trust and key exchange; symmetric carries the data itself.



TOPIC 3A · CRYPTOGRAPHIC ALGORITHMS

Hashing and the avalanche effect

- **Fixed length** data of any size produces a same-sized digest
- **Deterministic** the same input always gives the same digest
- **One way** you cannot work back from a digest to the original data
- **Avalanche effect** one changed bit transforms the whole digest
- **Collision resistant** two different inputs should not share a digest
- **Integrity only** hashing hides nothing at all



CHAPTER 2 · INTEGRITY, SIGNATURES & TRUST

Hashing algorithms today

Algorithm	Status	Where you meet it
SHA-256	Secure	File integrity and certificate signatures
SHA-1	Broken by collision attacks	Legacy systems only
Message Digest five	Broken, collisions on demand	Old checksums, never for security

Use SHA-256 or stronger. Treat anything weaker as broken.



TOPIC 3A · CRYPTOGRAPHIC ALGORITHMS

Digital signatures

- **The recipe** hash the message, then encrypt that hash with the sender private key
- **Sent together** the message and the signature travel as one
- **Verification** the recipient decrypts the signature with the sender public key and hashes the message
- **Matching digests** prove the message is intact and came from the holder of that private key
- **Provides** integrity, authentication and non-repudiation
- **Not confidentiality** a signature does not hide the content

Sign with the private key, verify with the public key.



QUIZ

Activity: which tool for which job?

- Encrypting a large database backup: symmetric or asymmetric?
- Proving a contract was not altered: hash or encrypt?
- Authenticating a sender beyond doubt: what mechanism?
- Exchanging a session key over an untrusted network: which approach?
- Debrief: name the job before naming the tool.

Bulk data → symmetric · integrity → hashing · identity → signatures · key exchange → asymmetric.



TOPIC 3B · PUBLIC KEY INFRASTRUCTURE

Certificates and certificate authorities

- **PKI** the machinery that makes a public key trustworthy
- **Certificate authority (CA)** verifies identity and issues certificates, signing each with its own private key
- **Registration authority (RA)** performs the identity checks on the authority's behalf
- **The certificate** binds a public key to a verified identity
- **Revocation** a compromised key is cancelled rather than trusted
- **Without the binding** a public key on its own proves nothing at all



TOPIC 3B · PUBLIC KEY INFRASTRUCTURE

Digital certificates

- **What it carries** the public key, the identity, the usage and the validity period
- **Also inside** the issuing CA and that authority's digital signature
- **Standard format** X.509
- **Common Name (CN)** the legacy FQDN field, deprecated but still met
- **Subject Alternative Name (SAN)** the modern field: multiple hosts, subdomains and wildcards
- **The exam favourite** CN versus SAN is a recurring distinction



TOPIC 3B · PUBLIC KEY INFRASTRUCTURE

Root of trust and the chain of trust

- **Root certificate** self-signed, so you trust the authority's own procedures
- **Intermediate authorities** certified by the root, issuing the end certificates
- **Leaf certificate** the one your browser actually uses
- **Trust flows down** trust the root and it vouches for the whole chain below it
- **Compromise below** revoke the certificate or the intermediate, not the root
- **Without PKI** certificates can exist, but give you no root of trust



TOPIC 3B · PUBLIC KEY INFRASTRUCTURE

The certificate signing request

1

Generate

the subject creates a key pair

2

Send

the public key goes to the CA in a CSR, never the private key

3

Verify

the CA, or an RA on its behalf, performs identity checks

4

Issue

the CA signs the certificate and publishes it

5

Renew

re-verification before the validity period ends



TOPIC 3B · PUBLIC KEY INFRASTRUCTURE

Certificate revocation

- **Revocation versus suspension** permanent removal versus a temporary hold
- **CRL** the certificate revocation list, a published checklist that clients download
- **OCSP** the online certificate status protocol, a real-time query about one certificate
- **Why revoke** compromised keys, changed details, trust that has expired
- **The lifecycle** issuance, renewal, revocation and expiration
- **The aim** a bad key must stop being trusted quickly



TOPIC 3B · PUBLIC KEY INFRASTRUCTURE

Key management and cryptoprocessors

Mechanism	What it is
TPM	Trusted Platform Module: a cryptoprocessor on the motherboard giving tamper-evident key storage and entropy for key generation
HSM	Hardware Security Module: a dedicated or removable cryptoprocessor managing keys at scale, with a reduced attack surface
Key escrow	Backup of keys with a trusted third party; M-of-N control splits recovery so no one agent acts alone
Key lifecycle	Generation, storage, revocation, expiration and renewal



DISCUSSION

What does a website certificate actually prove?

Probe: it proves the public key belongs to the named domain, and that a trusted authority vouched for that binding. It does not prove the site is safe or legitimate, and it says nothing about the content.

Certificates prove identity and key binding; they do not vouch for the content.



BREAK
10 MINUTES

Back soon: cryptographic solutions, then identity and access management.



TOPIC 3C · CRYPTOGRAPHIC SOLUTIONS

Data states

- **Data at rest** stored data: disks, databases, backups and files
- **Data in transit** moving across a network, protected by transport encryption
- **Data in use** being processed in memory, the hardest state to protect
- **The rule** every state needs an appropriate control
- **The exam** scenario questions match a state to a tool
- **Start here** name the state before you name the technology



TOPIC 3C · CRYPTOGRAPHIC SOLUTIONS

Disk and file encryption

- **Full disk or partition** encrypt the whole volume, often driven by the OS or firmware
- **File and volume encryption** encrypt selected files or containers
- **Self-encrypting drives** encryption performed by the drive firmware itself
- **The benefit** a stolen drive yields nothing without the key
- **At scale** BitLocker and FileVault protect at-rest data
- **The weak point** a running machine with the key in memory



TOPIC 3C · CRYPTOGRAPHIC SOLUTIONS

Database encryption

- **Levels** database, table, column and cell or record level
- **Fine-grained access** column and record encryption enforce precise control
- **How it works** the database management system decrypts as data moves into memory
- **Compliance** supports privacy and security requirements
- **The trade-off** fine granularity adds complexity and overhead
- **Choose by need** protect the columns that carry the sensitive data



TOPIC 3C · CRYPTOGRAPHIC SOLUTIONS

Transport encryption and perfect forward secrecy

- **Transport encryption** protects data in transit: TLS and VPN tunnels
- **The session key** an asymmetric handshake exchanges a symmetric session key
- **Perfect forward secrecy** session keys are ephemeral, so they are never reused
- **The guarantee** compromise of one key cannot decrypt past traffic
- **The result** recorded traffic stays encrypted even if keys leak later
- **Why it matters** a modern requirement, not a luxury



TOPIC 3C · CRYPTOGRAPHIC SOLUTIONS

Salting and key stretching

- **The problem** user-chosen passwords are low entropy, so brute force finds them
- **Salting** add a random value per password before hashing, which defeats pre-computed tables
- **Key stretching** extra hashing rounds make every guess expensive
- **Together** slower attacks and safer stored passwords
- **Never plain** store only salted, stretched hashes
- **The pairing** salt plus stretch, never one alone



CHAPTER 3 · APPLICATIONS & THE PAPER TRAIL

Blockchain: a distributed ledger

- **Distributed** copied across many nodes, so there is no single master copy
- **Each block holds** transactions, a timestamp and the hash of the previous block
- **The chain** the previous hash is what links the blocks together
- **Tamper-evident** altering an old block breaks every block after it
- **Rewriting history** means redoing every later block and controlling most of the network
- **Why it works** hashing is what makes the ledger tamper-evident



CHAPTER 3 · APPLICATIONS & THE PAPER TRAIL

Blockchain: applications and limits

Area	Detail
Supply chain	Immutable audit trail of provenance and handling
Identity	Decentralised credentials, less exposed to any single breach
Records	Medical, legal and financial records that cannot be altered silently
Scalability	The ledger grows, and public consensus is slow and costly
Energy	Proof of work consumes significant energy
Regulation	Rules vary by jurisdiction and are still evolving

A tool with a narrow best use: a shared, unchangeable record, not a general answer.



Obfuscation: making data hard to understand

- **Tokenisation** replace a value with a token and keep the real value in a secure vault
- **In the real world** payment card numbers are protected this way
- **Data masking** realistic but fictitious data for test environments
- **Code obfuscation** renamed variables, stripped comments and convoluted logic
- **The effect** reverse engineering becomes expensive
- **Not encryption** the goal is confusion, not secrecy



CHAPTER 3 · APPLICATIONS & THE PAPER TRAIL

Steganography

- **Conceals existence** it hides that a message is there, not what the message says
- **Images** alter the least significant bits of the pixels
- **Audio** change frequencies that listeners cannot hear
- **Legitimate uses** watermarking media and protecting intellectual property
- **Malicious uses** hiding malware, covert channels and data exfiltration
- **The distinction** encryption makes data unreadable; steganography makes it invisible



CHAPTER 3 · APPLICATIONS & THE PAPER TRAIL

Documentation and change management

- **The set** policies state the rules, procedures give the steps, diagrams show reality
- **Keep it current** update diagrams, policies and procedures whenever something changes
- **Compliance** documentation proves your practices to regulators
- **Incident response** the first thing you establish is what the environment actually is
- **Change control** a rollback plan is documented before a change is approved
- **Knowledge transfer** documentation carries knowledge when people leave



CHAPTER 3 · APPLICATIONS & THE PAPER TRAIL

Version control concepts

Concept	What it holds
Repository	All project files plus the full history of changes
Commit	A snapshot with a unique identifier and a message
Branch	An independent line of work that leaves the stable version alone
Value	Track changes, collaborate, and answer what changed and when

When an auditor asks what changed after an incident, this history is your answer.



QUIZ

Activity: match the technique

- A backup tape is stolen: which control protects the data?
- A web session must survive key compromise: which property?
- Storing passwords: what two techniques must you apply?
- Hiding a message inside a photo: which technique?
- Proving a ledger entry was never altered: which property?
- Debrief: state first, then tool.

At rest → disk or file encryption · in transit → TLS with PFS · passwords → salt and stretch · hidden → steganography · tamper-evident → the hash chain.



CHAPTER 4 · IDENTITY & ACCESS MANAGEMENT

Authentication and authorisation

- **Authentication** are you who you say you are?
- **Authorisation** what are you allowed to do?
- **Proving identity** a password, a token or a biometric
- **Deciding permissions** which records you may read, edit or delete
- **Least privilege** the minimum access needed to do the job, and nothing beyond it
- **Why it matters** it limits the damage from mistakes as much as from malice



CHAPTER 4 · IDENTITY & ACCESS MANAGEMENT

Roles and the identity lifecycle

- **Role-based access control** assign permissions to roles, then assign people to roles
- **Access follows the job** doctors, nurses and administrators each receive what the work needs
- **Provisioning** create the identity and grant access when someone joins
- **Modification** adjust permissions when the role changes
- **Deprovisioning** disable the account and remove access when someone leaves
- **The open door** a forgotten account is an account an attacker can use



CHAPTER 4 · IDENTITY & ACCESS MANAGEMENT

The three factors

Factor	Examples
Something you know	Password, personal identification number
Something you have	Hardware token, smart card, authenticator app
Something you are	Fingerprint, face, iris
Multi-factor	Two or more different factors, such as a password plus a token
Single factor	A password plus a personal identification number is still one factor

Multi-factor means two or more different families, not two secrets from the same one.



CHAPTER 4 · IDENTITY & ACCESS MANAGEMENT

Stronger authentication

- **Multi-factor** your best defence against a stolen password
- **Time-based one-time password** a shared secret combined with the current time
- **The window** the code stays valid for a short period, typically 30 to 60 seconds
- **Phishing** a code can be relayed, so a hardware key is stronger
- **Passwordless** a biometric, a device key, or a link sent to you
- **The benefit** fewer passwords means less reuse and fewer breaches



CHAPTER 4 · IDENTITY & ACCESS MANAGEMENT

Single sign-on and SAML

- **One login** opens many applications
- **For users** less password fatigue and less password reuse
- **For administrators** one place to enforce policy, watch access and revoke it quickly
- **SAML** the Security Assertion Markup Language exchanges authentication assertions
- **Identity provider** authenticates the user and issues the signed assertion
- **Service provider** trusts the assertion and grants access, so the password never reaches the application



CHAPTER 4 · IDENTITY & ACCESS MANAGEMENT

Federation and its risks

- **What it is** partners agree on standards and trust each other's identity providers
- **The benefit** staff reach the other organisation's resources without a second account
- **The risk** one login is also one point of failure, with a wide blast radius
- **Sessions** manage sessions, set sensible timeouts and handle cookies securely
- **Tokens** encrypt tokens in transit with TLS
- **MFA** add it at the identity provider, where one control protects every application



CHAPTER 5 · CONTROLLING ACCESS

RADIUS: central network authentication

- **RADIUS** Remote Authentication Dial-In User Service, an open standard
- **What it provides** authentication, authorisation and accounting
- **Clients** switches, wireless access points and VPN gateways
- **Servers** verify credentials, often against a directory, and answer accept or reject
- **Where you meet it** VPN access and wireless 802.1X
- **The point** one place to decide who may join the network



CHAPTER 5 · CONTROLLING ACCESS

RADIUS and TACACS+

Feature	RADIUS	TACACS+
Transport	UDP, fast but less reliable	TCP, reliable delivery
Functions	Combines authentication and authorisation	Separates all three functions
Granularity	Coarse	Command-level authorisation
Origin	Open standard	Developed by Cisco, widely supported
Best for	Network access: VPN, wireless	Managing network devices

Use RADIUS for network access, and TACACS+ for managing the devices themselves.



CHAPTER 5 · CONTROLLING ACCESS

Directory services and LDAP

- **A directory** a database built for reading and searching
- **LDAP** the Lightweight Directory Access Protocol
- **The shape** a hierarchy of organisational units, groups and user objects
- **User objects** carry attributes: a name, an email address and login details
- **Active Directory** the Microsoft implementation, adding Group Policy and Kerberos
- **The design** fast lookups, and writing is deliberately uncommon



CHAPTER 5 · CONTROLLING ACCESS

Authenticating against a directory

1

Bind

send the credentials
to the server

2

Search

find the matching user
object

3

Compare

check credentials
against the stored
values

4

Result

return success or
failure

5

Encrypt

389 is clear by default;
use LDAPS on 636 or
StartTLS



CHAPTER 5 · CONTROLLING ACCESS

Access control lists and models

- **An access control list** a list of permissions attached to an object
- **Each entry** names a subject and an action that is allowed or denied
- **Order matters** entries are read in order and the first match wins
- **No match** the default applies, and that is normally deny
- **Example** allow 192.168.1.0/24, deny everything else
- **The models** discretionary: the owner sets permissions. Mandatory: a central policy decides



CHAPTER 5 · CONTROLLING ACCESS

Attributes, place and time

- **Attribute-based access control** evaluates user, resource and environmental attributes together
- **Example policy** finance documents, for finance staff, on managed devices
- **Geofencing** access only inside an approved area
- **Time-based restrictions** access only during defined periods
- **The effect** every restriction lowers the value of a stolen credential
- **The exam skill** ask which model a scenario describes



KEY TAKEAWAYS

- **Symmetric for bulk, asymmetric for keys** one key is fast but hard to share; pairs solve distribution.
- **Hash for integrity, sign for identity** sign with private, verify with public; signatures add non-repudiation.
- **Certificates bind keys to identities** X.509, CA chains, the root of trust, CRL and OCSP.
- **Protect every data state** at rest with disk, file and database encryption; in transit with TLS and perfect forward secrecy.
- **Obfuscate, hide and record** tokenisation, masking, steganography, blockchain, documentation and version control.
- **Identity is separate from access** authentication proves who you are; RADIUS, TACACS+ and LDAP centralise the rest.



QUIZ

Check your understanding

- Open Quiz_Session_06.html in your browser.
- 20 questions, immediate feedback, exam-objective tag on every question.
- Read each explanation: the distractors teach as much as the answer.
- Score 70%+ before moving on.

Every question maps to a CompTIA exam objective, e.g. 3.1 Cryptographic Algorithms.



EXAM ALIGNMENT

What this maps to in the exam

Objective	What the exam tests
3.1 Cryptographic algorithms	Symmetric, asymmetric, hashing, key length and digital signatures
3.2 PKI and certificates	CAs, X.509, root of trust, CSR, revocation and key management
3.3 Cryptographic solutions	Data states, disk, file, database and transport encryption, PFS, salting
3.4 Identity and access	Authentication versus authorisation, factors, MFA, SSO, SAML and federation
3.5 Access control	RADIUS, TACACS+, LDAP and the access control models



REVISION CHECKLIST

Before next session

- **Retake the quiz** until you score 70%+ without guessing
- **Practise the jobs** for five data types, name the right cryptographic tool
- **Inspect certificates** look at a browser certificate's SAN and its chain of trust
- **Learn the protocol split** RADIUS versus TACACS+, and LDAP on 389 versus LDAPS on 636
- **Read ahead** Session 7: the threat landscape, its actors, attack surfaces and malware



NEXT SESSION

Session 7 — The Threat Landscape

- Threat actors, their attributes and their motivations
- The attack surface, and the vectors that reach it
- Malware, credential attacks and the mitigations that answer them

